

Exploit ID	Description	Target IP	Status	Payload
004	XSS to RCE Chain	192.168.0.106	Success	Meterpreter

Customization: Python PoC Modification

The original Exploit-DB Python PoC for CVE-2021-22205 was modified to accept dynamic target URLs and custom reverse shell parameters. Error handling and request headers were improved for stability. Payload execution was validated in a controlled lab, ensuring reliable command execution without altering exploit logic.

A chained attack was successfully simulated on host **192.168.0.106**, starting with a stored Cross-Site Scripting (XSS) vulnerability and escalating to Remote Code Execution (RCE). Exploitation leveraged **CVE-2021-22205**, resulting in a successful **Meterpreter session**, confirming full system compromise within a controlled Metasploitable2 lab environment.

Remediation

- Sanitize and validate all user inputs
- Implement output encoding to prevent XSS
- Update and patch GitLab to address CVE-2021-22205
- Restrict file uploads and execution permissions
- Conduct regular vulnerability scanning and patch management

Dear Development Team,

During a recent security assessment, we identified a critical exploit chain on the web server (192.168.1.100). A stored XSS vulnerability was leveraged to escalate privileges and exploit CVE-2021-22205, resulting in remote code execution and a Meterpreter shell. This confirms full system compromise under lab conditions. Immediate remediation is recommended, including strict input sanitization, output encoding, and updating GitLab to the latest patched version. We also advise reviewing file upload controls and conducting a follow-up security scan after fixes are applied.

Regards,
Shashank M